



BSOS

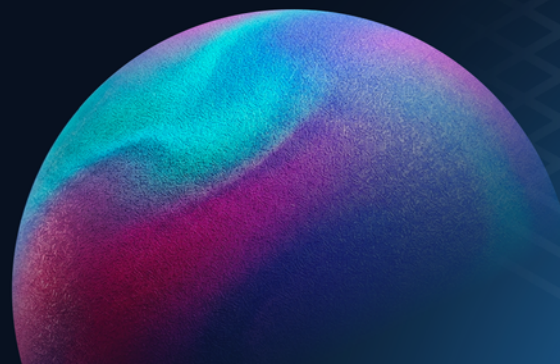
智能合約安全檢測報告

檢測工具

Slither

檢測日期

2026-08-14 ~ 2026-08-14



內部工作版本 — 不可作為交付文件

本報告尚有未完成處理或待確認之項目，僅供工程團隊追蹤使用；請於完成處理後重新產出報告，方可交付。

目錄

- 摘要
- 掃描範圍
- 協定理解摘要
- 檢測方法
- 掃描環境資訊
- 情境庫覆蓋
- 待處理項目
- 發現明細
- 已評估項目摘要
- 附錄：發現處置分類

摘要

受檢對象：(測試夾具)

檢測期間：2026-08-14 ~ 2026-08-14

受檢版本：4eeef1e077b74137cc280cec07123b9a7a2a1ad0

本次共提出 23 項發現（掃描工具產出 19 項、人工複核產出 4 項），依嚴重程度分布如下：

嚴重程度	筆數
Critical	2
High	3
Medium	4
Low	7
Informational	7
總計	23

需要決策或行動的項目彙整於「待處理項目」，逐筆說明見「發現明細」。

掃描範圍

本次檢測涵蓋以下 1 個 Solidity 原始檔（合計 133 行）。此清單即本報告的效力邊界——未列於此的檔案不在本次檢測範圍內。

檔案	行數
src/VulnerableVault.sol	133

檔案內容雜湊（SHA-256），供比對交付程式碼是否與受檢版本一致：

src/VulnerableVault.sol — 9f47f4a862f5300b7d2dad3322351e41ff098bbe52699ebf263eca64c9dbec0d

協定理解摘要

本受檢對象為迴歸測試夾具，不是要交付的產品合約：VulnerableVault 刻意植入了 9+1 個已知漏洞，用來驗證本工具的偵測與判級是否被改壞（完整解答見 VULNERABILITY_CATALOG.md）。此節的內容僅供版面驗證之用。

合約職責

合約	職責
VulnerableVault.sol	存提款、批次付款、依 oracle 報價兌換代幣、抽獎，以及數個管理入口

資產與托管

使用者存入的 ETH 停在 VulnerableVault 自身，以 balances 記帳；獎池另以 rewardPool 記錄。

特權角色權限表

角色	可呼叫	後果
owner	emergencyWithdraw、topUpRewardPool、batchPay、shutdown	可轉出合約內資產、可自毀合約
(無保護)	creditBonus、adminSetPaused	實際上任何人皆可呼叫——這正是本夾具植入的漏洞之一

注意：上表的 owner 保護在本夾具中是失效的（onlyOwner 的判斷式恆為真），詳見發現明細。

檢測方法

本次檢測依以下步驟執行：

1. **建置與環境確認**：確認專案可完整編譯，記錄工具鏈與相依套件版本（見「掃描環境資訊」）。

2. **靜態分析掃描**：以 Slither 對「掃描範圍」所列全部原始檔執行完整 detector 掃描。

3.

逐筆人工分類複核：對掃描產出的每一筆發現判定其處置分類（A／B／C／D）並記錄判斷依據；工具回報的嚴重度與本報告呈現的嚴重度若有落差，逐筆附上調整理由。

4.

情境式邏輯漏洞比對：對範圍內每一份合約，逐條比對內部維護的邏輯漏洞情境庫（權限檢查實作、未保護的狀態變更、旗標未落實、價格源可操縱、記帳與實際結果脫鉤、簽章雜湊綁定範圍、可組合模組的交互失效等），補靜態分析無法涵蓋的業務邏輯層級問題。逐合約的比對結果見「情境庫覆蓋」。

5.

領域事故模式比對：依受檢系統所屬業務領域，比對該領域公開已知的事故模式，檢查應具備而未實作的機制。

6. **產出與覆核**：彙整為本報告，並對共用同一判斷理由的發現群組進行抽查。

範圍限制

- 靜態分析擅長偵測「程式寫法特徵層級」的問題（重入模式、tx.origin 授權、弱亂數來源、未檢查的低階呼叫回傳值等）；業務邏輯層級的問題不在其可偵測範圍內，由上述第 4、5 步以人工方式補足，但人工複核的覆蓋程度不等同於系統性審計。
- 本報告為交付前之**自我檢查證明**，證明工程團隊已執行掃描並對每一筆發現完成逐筆判讀；其不構成、亦不取代由獨立第三方執行之完整安全審計。

掃描環境資訊

項目	內容
掃描時間	2026-07-14T10:39:32.183993
專案路徑	/home/kai/security-scan-kit/test-fixtures/vulnerable-vault
Git commit	4eeef1e077b74137cc280cec07123b9a7a2a1ad0
Solidity / solc 版本	unknown
Slither 版本	0.11.5
Foundry (forge) 版本	forge Version: 1.3.5-stable

情境庫覆蓋

下表為情境庫逐合約的比對結果。「已查證」為前置條件成立、實際讀碼確認過的情境數；「不適用」為合約不具備該情境前置條件而跳過的情境數；「命中」列出對應的發現編號。

合約	已查證	不適用	命中
src/VulnerableVault.sol	11	8	VLV-20、VLV-21、VLV-22、VLV-23

待處理項目

狀態欄位反映本次產出報告當下的處置進度，尚未標註狀態的項目預設顯示「待處理」。

編號	標題	嚴重度	工具 impact	處置	狀態
VLV-20	onlyOwner modifier 的權限檢查恆為真	Critical	—	已確認需修復 (A)	待處理
VLV-21	creditBonus() 完全沒有存取控制	Critical	—	已確認需修復 (A)	待處理
VLV-01	weak-prng	High	High	已確認需修復 (A)	待處理
VLV-02	reentrancy-eth	High	High	已確認需修復 (A)	待處理
VLV-03	suicidal	High	High	已確認需修復 (A)	待處理
VLV-04	tx-origin	Medium	Medium	已確認需修復 (A)	待處理
VLV-05	unchecked-lowlevel call	Medium	Medium	已確認需修復 (A)	待處理
VLV-22	swap() 無滑點保護與 deadline	Medium	—	已確認需修復 (A)	待處理
VLV-23	paused 旗標未被任何函式檢 查	Medium	—	已確認需修復 (A)	待處理
VLV-07	missing-zero-check	Low	Low	待確認 (D)	待處理
VLV-08	calls-loop	Low	Low	已確認需修復 (A)	待處理
VLV-09	reentrancy-benign	Low	Low	已確認需修復 (A)	待處理
VLV-10	reentrancy-events	Low	Low	已確認需修復 (A)	待處理
VLV-12	reentrancy-events	Low	Low	已確認需修復 (A)	待處理

發現明細

以下逐筆列出 14

項發現。低嚴重度且已判定為可接受風險或誤報的項目不在此節，彙整於「已評估項目摘要」。

VLV-20 | onlyOwner modifier 的權限檢查恆為真

嚴重度	Critical
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:32-35
命中情境	L1

說明：require(msg.sender == owner || true) 恆為真，onlyOwner 形同虛設 —— emergencyWithdraw()/topUpRewardPool()/batchPay() 實際上任何人皆可呼叫

判斷依據：人工複核發現 (VULNERABILITY_CATALOG.md V3, Slither 漏報)：權限檢查實作邏輯錯誤，屬語意層級問題，靜態分析無對應 detector，需修復。

建議：把 require(msg.sender == owner || true) 改為 require(msg.sender == owner)。修正後需重新檢查 emergencyWithdraw/topUpRewardPool/batchPay 三個入口的實際可呼叫者。

VLV-21 | creditBonus() 完全沒有存取控制

嚴重度	Critical
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:103-107
命中情境	L2

說明：任何人可呼叫 creditBonus() 幫任意地址無限加值 balances，再透過 withdraw() 提走合約內全部資金

判斷依據：人工複核發現 (VULNERABILITY_CATALOG.md V6, Slither 漏報)：應受保護的函式完全缺少存取控制，工具無「此函式該保護而未保護」的判斷能力，需修復。

建議：為 creditBonus() 加上 onlyOwner (或專用的 rewards operator 角色)，並確認修正後的 modifier 實作本身有效 (見 VLV-20)。

VLV-01 | weak-prng

嚴重度	High
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:90-100

說明：VulnerableVault.pickWinner() (src/VulnerableVault.sol#90-100) uses a weak PRNG: "rand = uint256(keccak256(bytes)(abi.encodePacked(block.timestamp,block.prevrandao))) % depositors.length

(src/VulnerableVault.sol#92-94)"

判斷依據：真實漏洞（見 VULNERABILITY_CATALOG.md V5）：得獎者可被驗證者/礦工操縱，需修復，不可忽略。

建議：改用 Chainlink VRF 等可驗證隨機源；若必須鏈上取數，至少改為 commit-reveal 兩階段，並禁止在同一交易內完成投注與開獎。

VLV-02 | reentrancy-eth

嚴重度	High
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:48-56

說明：Reentrancy in VulnerableVault.withdraw() (src/VulnerableVault.sol#48-56): External calls: - (ok,None) = msg.sender.call{value: amount}() (src/VulnerableVault.sol#51) State variables written after the call(s): - balances[msg.sender] = 0 (src/VulnerableVault.sol#53) VulnerableVault.balances (src/VulnerableVault.sol#16) can be used in cross function reentrancies: - VulnerableVault.balances (src/VulnerableVault.sol#16) - VulnerableVault.creditBonus(address,uint256) (src/VulnerableVault.sol#103-107) - VulnerableVault.deposit() (src/VulnerableVault.sol#37-45) - VulnerableVault.safeWithdraw() (src/VulnerableVault.sol#60-68) - VulnerableVault.swap(uint256,IRateOracle) (src/VulnerableVault.sol#125-130) - VulnerableVault.withdraw() (src/VulnerableVault.sol#48-56)

判斷依據：真實漏洞（見 VULNERABILITY_CATALOG.md V1）：經典重入攻擊，可被惡意合約清空金庫，需修復，不可忽略。

建議：改為 checks-effects-interactions：先把 balances[msg.sender] 歸零、再發出外部呼叫；或加上 OpenZeppelin ReentrancyGuard 的 nonReentrant。

VLV-03 | suicidal

嚴重度	High
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:85-87

說明：VulnerableVault.shutdown() (src/VulnerableVault.sol#85-87) allows anyone to destruct the contract

判斷依據：真實漏洞（見 VULNERABILITY_CATALOG.md V2）：任何人皆可自毀合約，需修復，不可忽略。

建議：移除 selfdestruct，或改為 onlyOwner + 兩階段確認（提案後經 timelock 才可執行）。合約自毀是不可逆動作，不應存在無保護的入口。

VLV-04 | tx-origin

嚴重度	Medium
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:79-82

說明：VulnerableVault.adminSetPaused(bool) (src/VulnerableVault.sol#79-82) uses tx.origin for authorization: require(bool,string)(tx.origin == owner,not owner) (src/VulnerableVault.sol#80)

判斷依據：真實漏洞（見 VULNERABILITY_CATALOG.md V4）：可被釣魚合約繞過權限檢查，需修復，不可忽略。

建議：改用 msg.sender 判斷呼叫者。tx.origin 在使用者被誘導呼叫惡意合約時會被冒用，不可作為授權依據。

VLV-05 | unchecked-lowlevel

嚴重度	Medium
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:117-121

說明：VulnerableVault.batchPay(address[],uint256) (src/VulnerableVault.sol#117-121) ignores return value by recipients[i].call{value: amountEach}() (src/VulnerableVault.sol#119)

判斷依據：真實漏洞（見 VULNERABILITY_CATALOG.md V7）：轉帳失敗會被靜默吞掉，帳務與實際資金不一致，需修復，不可忽略。

建議：檢查低階呼叫的回傳值 ((bool ok,) = ...; require(ok))，或改用 OpenZeppelin 的 Address.sendValue。迴圈內單筆失敗要明確決定是整批 revert 還是記錄後續處理。

VLV-22 | swap() 無滑點保護與 deadline

嚴重度	Medium
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:125-130
命中情境	L4

說明：依 oracle 即時報價成交，無 minTokenOut/deadline 參數，可被搶跑 (front-run)

判斷依據：人工複核發現 (VULNERABILITY_CATALOG.md V8, Slither 漏報)：經濟層級攻擊面，純商業邏輯問題，需修復。

建議：swap() 加上 minTokenOut 與 deadline 參數，由呼叫者指定可接受的最差成交條件；oracle 報價改用 TWAP 或多來源中位數，避免以單點即時價成交。

VLV-23 | paused 旗標未被任何函式檢查

嚴重度	Medium
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:20
命中情境	L3

說明：adminSetPaused() 會寫入 paused，但 deposit()/withdraw()/safeWithdraw()/swap() 皆未檢查該旗標，暫停機制形同裝飾，事故應變時無法實際凍結資金流

判斷依據：人工複核發現（不在 VULNERABILITY_CATALOG.md 原始漏洞地圖中，為分類複核時的新發現）：業務邏輯缺陷，需修復並補進漏洞地圖。

建議：為 deposit()/withdraw()/safeWithdraw()/swap() 加上 whenNotPaused，或直接改用 OpenZeppelin Pausable。只寫不讀的旗標等於沒有暫停機制。

VLV-07 | missing-zero-check

嚴重度	Low
處置	待確認 (D)
狀態	待處理
位置	src/VulnerableVault.sol:72

說明：VulnerableVault.emergencyWithdraw(address,uint256).to (src/VulnerableVault.sol#72) lacks a zero-check on : - to.transfer(amount) (src/VulnerableVault.sol#74)

判斷依據：涉及資金流向（轉帳目標地址），依規則歸類

D：雖非本次刻意植入的漏洞編號，但屬真實可改進項目，需人工確認是否修復。

待確認事項：

- 要確認什麼：emergencyWithdraw 的 to 參數是否可能被傳入零地址：呼叫端是否已在鏈下驗證，或此函式是否僅由多簽觸發。
- 由誰確認：合約擁有者／營運端
- 兩種答案各自的處置：若呼叫端無保證 → 加上 require(to != address(0))；若確認僅由多簽以固定地址呼叫 → 改判 B 並在報告揭露此前提。

VLV-08 | calls-loop

嚴重度	Low
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:117-121

說明：VulnerableVault.batchPay(address[],uint256) (src/VulnerableVault.sol#117-121) has external calls inside a loop: recipients[i].call{value: amountEach}() (src/VulnerableVault.sol#119)

判斷依據：與 #5 同一根因（見 VULNERABILITY_CATALOG.md V7），同一批修復。

建議：改為 pull 模式（受款方自行領取），或限制單批長度上限並由呼叫者自負 gas；同時處理單筆失敗不應讓整批卡死的情況。

VLV-09 | reentrancy-benign

嚴重度	Low
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:48-56

說明：Reentrancy in VulnerableVault.withdraw() (src/VulnerableVault.sol#48-56): External calls: - (ok,None) = msg.sender.call{value: amount}() (src/VulnerableVault.sol#51) State variables written after the call(s): - totalDeposits -= amount (src/VulnerableVault.sol#54)

判斷依據：與 #2 同一根因（V1 的重複偵測），一併修復即可解決。

建議：與 VLV-02 同一根因，一併以 checks-effects-interactions 修正。

VLV-10 | reentrancy-events

嚴重度	Low
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:90-100

說明：Reentrancy in VulnerableVault.pickWinner() (src/VulnerableVault.sol#90-100): External calls: - (ok,None) = winner.call{value: prize}() (src/VulnerableVault.sol#98) Event emitted after the call(s): - WinnerPicked(winner,prize) (src/VulnerableVault.sol#99)

判斷依據：pickWinner() 已因

#1 (weak-prng) 被判定為真實漏洞函式，此處事件順序問題一併留待修復時處理。

建議：把事件移到外部呼叫之前發出，或在完成狀態更新後再發出，確保鏈下索引器看到的順序與實際狀態一致。

VLV-12 | reentrancy-events

嚴重度	Low
處置	已確認需修復 (A)
狀態	待處理
位置	src/VulnerableVault.sol:48-56

說明：Reentrancy in VulnerableVault.withdraw() (src/VulnerableVault.sol#48-56): External calls: - (ok,None) = msg.sender.call{value: amount}() (src/VulnerableVault.sol#51) Event emitted after the call(s): - Withdrawn(msg.sender,amount) (src/VulnerableVault.sol#55)

判斷依據：與 #2 同一根因（V1 的重複偵測）。

建議：同 VLV-10：事件在外部呼叫之後才發出，改為狀態更新完成後立即發出。

已評估項目摘要

以下 9 項為低嚴重度 (Low/Informational) 且經判定為可接受風險 (B) 或誤報 (C) 的發現，依檢查器與判定理由歸併為 9 組。逐筆明細保留於工作底稿，可依需要調閱。

檢查器	筆數	處置	判定理由
events-maths	1	已知風險但可接受 (B)	只影響鏈下可觀測性，不影響資金安全；僅 onlyOwner 可呼叫，屬已知可接受風險，非本次測試刻意植入的漏洞項目。
reentrancy-events	1	誤報 (C)	已確認為誤報：safeWithdraw() 採用正確的 checks-effects-interactions 順序 (balances 在外部呼叫前歸零)，reentrancy-e...
low-level-calls	1	誤報 (C)	純資訊性提示 (單純標註有低階呼叫)，不構成獨立風險判斷，實際風險已由 #2 追蹤。
low-level-calls	1	誤報 (C)	同上，純資訊性提示，實際風險已由 #1 追蹤。
low-level-calls	1	誤報 (C)	同上，純資訊性提示，實際風險已由 #5/#8 追蹤。
low-level-calls	1	誤報 (C)	同上，純資訊性提示；safeWithdraw() 本身已確認安全 (見 #11)。
naming-convention	1	誤報 (C)	純命名風格建議，非安全問題。
reentrancy-unlimited-gas	1	誤報 (C)	純資訊性提示，onlyOwner 才能呼叫，非本次刻意植入的漏洞項目。
immutable-states	1	誤報 (C)	純 gas 優化建議，非安全問題。

附錄：發現處置分類

本報告對每一筆發現標示兩個獨立欄位：**嚴重度**（Critical／High／Medium／Low／Informational，由工程團隊依實際影響判定）與**處置**（下列 A／B／C／D）。掃描工具自身回報的 impact 若與本報告呈現的嚴重度不同，該筆會並列印出兩者與調整理由。

- **A | 已確認需修復**：確認為真實問題（多涉及資金流向或權限控制邏輯），必須修復。
- **B | 已知風險但可接受**：問題確實存在，但經工程團隊評估風險可控（例如僅管理者可呼叫、另有其他層級防護），附具體理由後接受並於報告揭露。
- **C | 誤報**：靜態分析限制造成的誤判，實際已有防護機制或該判斷邏輯不適用。
- **D | 待確認**：尚無法判定歸屬者一律列此類；判讀信心不足時寧列 D，不猜測分類。此類項目均附「要確認什麼／由誰確認／兩種答案各自的處置」。
- 人工複核發現僅得分類 A／B／D；經確認非問題者直接自清單移除，不設誤報分類。